



File No.: EXP202213537

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure conducted by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On October 5, 2022, and November 4, 2022, two notifications of security breaches were received from MARKTEL GLOBAL SERVICES S.A. (hereinafter MARKTEL) with entry registration numbers REGAGE22e00044254458 and REGAGE22e00049917967.

From the content of both notifications, the following relevant information is extracted:

- Description of the breach: "(...)."

(...)

SECOND: On October 22, 2022, and November 21, 2022, two breach notifications were received from ORANGE ESPAGNE SAU (hereinafter ORANGE or ORANGE ESPAGNE), from which the following information is extracted:

- Description: "(...)."

THIRD: On October 28, 2022, and entry registration REGAGE22e00048666972, a notification of a security breach was received from the data controller ORANGE BANK SA (BRANCH IN SPAIN) (hereinafter, ORANGE BANK) with the following highlighted information:

- Description: "(...)."

FOURTH: On November 18, 2022, Mr. A.A.A. (hereinafter, the first complainant) filed a complaint with the Spanish Agency for Data Protection. The complaint is directed against ORANGE ESPAGNE and MARKTEL.

The reasons on which the complaint is based are as follows:

"The complainant is a customer of JAZZTEL who was informed by the operator that his personal data (...) may have been exposed as a result of a security incident affecting a company supplier. The affected party requested clarification on the exposed data, receiving in response all the data listed above, except (...)."

Date on which the claimed events took place: November 11, 2022.

Relevant documentation provided by the complainant:

- A screenshot of the email received from JAZZTEL communicating the security breach and informing about the impact on his personal data, dated November 11, 2022.
- A screenshot of the response given by the user to JAZZTEL after receiving the previous email, requesting more information about the security incident and the impact on his personal data.
- A screenshot of the response given by JAZZTEL to the previous email sent by the user, offering the complainant more details about the breach. This email is dated November 17, 2022.

FIFTH: On December 9, 2022, Mr. B.B.B. (hereinafter, the second complainant) filed a complaint with the Spanish Agency for Data Protection. The complaint is directed against ORANGE and MARKTEL.

The reasons on which the complaint is based are as follows:

"The complainant is a customer of ORANGE who was informed by the operator that his personal data (...) may have been exposed as a result of a security incident affecting a company supplier."

Date on which the claimed events took place: December 9, 2022.

Relevant documentation provided by the complainant:

Screenshots of the emails received from ORANGE communicating the leak of his personal data are attached. The content of this email is signed by both the DPO of ORANGE and ORANGE BANK, referencing that both entities act as data controllers, as ORANGE BANK is responsible for financing the devices purchased by the customer whose personal data has been affected.

SIXTH: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), on December 23, 2022, these complaints were forwarded to ORANGE ESPAGNE and MARKTEL for them to analyze and inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The following information was requested:

- Detailed and chronological description of the events.
- Causes that made the incident possible.
- Persons and categories of personal data affected.
- Possible consequences for the affected individuals.
- Actions taken to resolve the incident.
- Risk analyses and concluded preventive security measures, as well as impact assessments if applicable.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/48

- Copy of the Record of Processing Activities where the incident occurred.
- Information regarding the possible communication to the affected individuals.
- Information regarding the possible notification of the incident to this Agency.

SEVENTH: On January 23, 2023, and entry records REGAGE23e00004620337 and REGAGE23e00004620561, a response was received from MARKTEL regarding the transfer of the first complaint, attaching the following documents:

- (...)

From such documentation, the following relevant information is extracted:

- (...)

(...)

(...)

(...):

(...):

☐

(...)

The following list of preventive measures that were implemented by MARKTEL is confirmed:

☐

(...)

The list of reactive measures adopted by MARKTEL after the incident is confirmed:

☐

(...)

(...)

- In the response to the transfer, a document with the risk analysis dated May 2018 and updated on October 20, 2022, is also attached; from this document, the following relevant information is extracted:

(...):

☐

(...)

- The Record of Processing Activities (RAT) of MARKTEL acting as the data processor for ORANGE/JAZZTEL is attached, collecting the following information:

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/48

- Regarding the communication to the affected individuals, it is stated that no notification was made by MARKTEL, as it acted at all times as the data processor of the affected personal data, and it is stated that MARKTEL merely followed the instructions of the affected data controller.

EIGHTH: On January 27, 2023, and entry records REGAGE23e00005596907 and REGAGE23e00005596460, a response to the transfer of the first complaint was received from ORANGE; from the analysis of the documentation provided, the following relevant information is extracted:

- (...)
- (...)
- (...)
- (...)
- (...)
- (...)
- (...)
- (...)
- (...):
- (...)

NINTH: Responses from MARKTEL and ORANGE to the second complaint were also received, from which no additional relevant information was obtained beyond what has already been analyzed in the previous background. From the response provided by ORANGE BANK (on January 22, 2023, and entry record REGAGE23e00004368876), the following relevant information is extracted:

- (...)
- (...)
- (...)
- (...)

TENTH: On February 18 and 28, 2023, both complaints were admitted for processing.

ELEVENTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the supervisory authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following aspects:

- (...):
- (...)
- (...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

5/48

- (...)

Taking into account the information obtained at this point in the investigation, on May 29, 2023, it was decided to make a new request for information addressed to MARKTEL, ORANGE ESPAGNE, ORANGE BANK, marked by the following lines of investigation:

- For MARKTEL:

-)a Investigate all possible data processing controllers affected by the data leak.
-)b Request the audit report conducted by Deloitte.
-)c Investigate the attack vector of the breach.
-)d Request accreditation of the listed and referenced preventive measures.

- For ORANGE ESPAGNE:

-)a Investigate the correct formalization of the data processing assignments.
-)b Investigate the possible loss of availability of the data due to the breach.
-)c Investigate the correct communication to the affected individuals.

- For ORANGE BANK:

-)a Investigate the proactive responsibility in risk analyses as the data controller and the communication

to the affected individuals.

On June 19, 2023, and entry records REGAGE23e00039953302, REGAGE23e00039953372, REGAGE23e00039953646, REGAGE23e00039953646, REGAGE23e00039953771, and REGAGE23e00039953828, a response to the request was received from MARKTEL; from the inspector's analysis, the following relevant information is extracted:

- (...)

- (...)

(...)

Regarding security measures, Clause 17 "Data Protection" subsection 2.6.d) of the contract states the following:

(...):

-

(...)

-

(...)

-

(...)

-

(...)

-

(...)

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/48

Annex III of the Information Security attached to the aforementioned Contract establishes the following:

(...)

1. SPECIFIC MEASURES REGARDING INFORMATION SECURITY

(...)

1.(...):

(...)

(...)

2.(...):

(...)

(...):

a.

(...)

b.

(...)

c.

(...):

V(...):

o

(...)

o

(...)

V(...)

V(...)

3. (...):

(...)

(...):

(...)

V

(...)

(a)

(...)

(b)

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/48

(c)

(...)

(...)

V

(...)

V

(...)

V

(...)

V

(...)

V

4.(...):

(...)

(...):

(...)

V

(...)

V

(...)

5.(...):

(...)

(...):

(a)

(...)

(b)

(...)

(c)

(...)

(d)

(...):

o

(...)

o

(...)

o

(...)

o

(...)

o
(...)

o
(...)

6.
(...):
(...)
(...)

7. Responsibility of the PROVIDER for non-compliance with this Annex.
(...).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
8/48

-
(...):
“(...).”

-
(...).

-
(...).

-
(...):
“(...)”

-
(...):
(...)

-
(...)

On June 19, 2023, and entry record REGAGE23e00039958481, a response to the request was received from ORANGE BANK. From the inspector's analysis, the following relevant information is extracted:

-
The registration of incidents with the documented breach is accredited; from the analysis of this record, the following is obtained:

)a In relation to the context of the breach: “(...)”

)b Corrective measures adopted by ORANGE BANK in addition to those implemented by MARKTEL in its action plan:

☐
(...)

☐
(...)

☐
(...)

)c

From ORANGE ESPAGNE, communication of the incident has been sent to the affected individuals, and they affirm that, to avoid confusion among ORANGE BANK customers, this responsible party decides to adhere to said communication.

-
A documented analysis of the impact or scope of the incident is carried out, concluding with the need to notify the breach.

-

The following detailed chronology of the incident is provided:

)a (...)

-

(...)

On June 20, 2023, and entry records REGAGE23e00040164903 and REGAGE23e00040165559, a response to the request was received from ORANGE ESPAGNE, from which the following relevant information is extracted, among others:

-

A copy of the contract signed between ORANGE ESPAGNE and MARKTEL is provided, which has already been analyzed in previous points.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/48

-

In relation to the accreditation of the notification of the breach to each affected responsible party, a screenshot of the emails sent on October 25, 2022, addressed to ORANGE BANK is provided; the content is as follows:

“(…)”

“(…)”

-

The following relevant statements made by ORANGE ESPAGNE are obtained:

)a “(…)”

)b “(…)”

)c

“(…)”

On October 26, 2023, it was decided to make a final request for information to ORANGE ESPAGNE marked by the following line of investigation:

-

(...)

On November 7, 2023, and entry record REGAGE23e00075433461, a response to the previous request was received, from which the following relevant information is extracted:

-

Two invoices from affected customers are provided, and the inspector verifies the existence of the following text included in the footer of the invoice:

” (...)”

TWELFTH: On February 16, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the investigated entity, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 5.1.f), classified in Article 83.5 of the GDPR.

The initiation agreement was sent, in accordance with the rules established in the LPACAP, via electronic notification, not being received by the responsible party within the availability period, being understood as rejected in accordance with the provisions of Article 43.2 of the LPACAP, on February 27, 2024, as stated in the certificate in the file.

Additionally, a copy was sent by postal mail, which was duly notified on February 19, 2024. In this notification, they were reminded of their obligation to interact electronically with the Administration, and were informed of the means of access to such notifications, reiterating that, henceforth, they would be notified exclusively by electronic means.

C/ Jorge Juan, 6

www.aepd.es

THIRTEENTH: In response to the written request for an extension of the deadline granted for submitting allegations, as well as a copy of the file, on February 23, 2024, it was agreed to extend the deadline for submitting allegations by a maximum of ten days, which should be counted from the day following the receipt of the copy of the file.

In compliance with the provisions of Article 53.1.a) of the LPACAP, on March 14, 2024, a physical support (CD or USB drive) was sent to the investigated entity via courier, containing the complete copy of the requested administrative file, as the size of the requested file exceeded the maximum allowed in the Notific@ system, used by the administrative bodies for the electronic practice of their notifications. On the same date, another document was independently sent through the aforementioned Notific@ platform, providing the key to access the documentation included in the physical support and agreeing to extend the deadline for submitting allegations by a maximum of ten days, which should be counted from the day following the receipt of the copy of the file.

FOURTEENTH: On April 3, 2024, in response to the written request for a copy of the CD provided by Orange, a copy of it was sent, in accordance with the provisions of Article 53.1 a) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP).

Regarding the entity's request to suspend the deadline for allegations until a copy of the file was provided, the instructing body of the procedure indicated that according to the provisions of Article 29 of the LPACAP, the terms and deadlines established therein bind the Public Administration and the interested parties, and although it contemplates the possibility of extending them, it does not regulate suspension for the reasons invoked.

FIFTEENTH: Once the aforementioned initiation agreement was notified in accordance with the rules established in the LPACAP, the investigated entity submitted a written statement of allegations.

SIXTEENTH: On December 27, 2024, a resolution proposal was formulated, proposing:

<< That the Director of the Spanish Agency for Data Protection sanctions ORANGE BANK, S.A. BRANCH IN SPAIN, with NIF W2503011E,

-for the infringement of Article 5.1.f) of the GDPR, classified in accordance with the provisions of Article 83.5 of the GDPR, qualified as very serious for the purposes of prescription, in Article 72.1 a) of the LOPDGDD, with a fine of 1,500,000 euros.

That the Director of the Spanish Agency for Data Protection orders ORANGE BANK, S.A. BRANCH IN SPAIN, with NIF W2503011E, to, pursuant to Article 58.2.d) of the GDPR, within six months from the finality of the resolution concluding this procedure, demonstrate that it has implemented the necessary measures to ensure the confidentiality of the data subject to its processing and to inform this Agency, within the same period, about the measures adopted.>>

The aforementioned resolution proposal was sent, in accordance with the rules established in the LPACAP, via electronic notification, being received on January 7, 2025.

SEVENTEENTH: On January 10, 2025, ORANGE BANK, S.A. BRANCH IN SPAIN, submitted a written request for an extension of the deadline granted for submitting allegations.

On January 14, 2025, the instructing body of the procedure agreed to extend the deadline by a maximum of five days, which should be counted from the day following the end of the first deadline for allegations.

The aforementioned agreement was notified on January 15, 2025, as evidenced by the acknowledgment of receipt in the file.

EIGHTEENTH: On January 14, 2025, ORANGE BANK, S.A. BRANCH IN SPAIN submitted a written statement of allegations to the Resolution Proposal, in which, in summary, it states that:

1. New arguments of the resolution proposal.

It states that in the written document all and each of the facts described in the initial statement of allegations are considered reiterated, as well as the legal grounds reasoned therein, and in this hearing process regarding the resolution proposal, only the reasoning, arguments, and elements necessary to respond and discuss those aspects in which the resolution proposal innovates compared

to the opening agreement of the sanctioning file are added.

2. Regarding the facts.

2.1 Number of data affected by the security breach.

It argues that the security breach being analyzed in this file has exclusively affected (...).

It adds that any mention of data other than those corresponding to the responsibility of Orange Bank S.A. Branch in Spain must be removed from the documents in the file, as they should not influence the assessment of the responsibility attributed to the entity, but, however, distort the relevance of the facts for which it must respond.

2.2 Number of data declared by Orange Bank S.A. Branch in Spain.

It states that Orange Bank S.A. Branch in Spain has notified the Agency of the security breach from the first moment it became aware of it, and has

12/48

also declared all the circumstances that concurred in said incident as they became known.

For this reason, it states that, in the first declaration, dated 28/10/2022, it was indicated that, according to the information available at that time, the data affected (...)

It considers that again, this reference to the update that impacts so specifically on the original and updated data has no influence on the assessment of the responsibility attributed to Orange Bank S.A. Branch in Spain, but distorts the image of the entity and generates the idea that it has attempted to conceal data and evade the Administration.

2.3 Unobfuscated IBAN numbers.

(...)

(...)

In summary, it states that during the two years in which Orange Bank S.A. Branch in Spain utilized the services of Marktél, half of the period the data was unobfuscated and the other half was obfuscated.

(...)

3. On the incompetence of the Spanish Data Protection Agency.

It states that Orange Bank S.A. Branch in Spain is, as its name indicates, a branch of the French bank Orange Bank S.A., a French financial company established in Montreuil, France. Orange Bank S.A. is 100% owned by Orange SA, the parent company of the France Telecom group.

It explains that by opening a branch in Spain, the French company, Orange Bank SA, has not modified its legal personality, domicile, or nationality in any way. The branch is an office of the French company. Therefore, for the attribution of responsibility, only the French company can be considered. It is impossible to attribute that responsibility to the branch, as it lacks its own legal personality, making it impossible to accuse it or impose any potential sanction. Legally, any action against the branch is an act executed against the parent company of the branch.

It considers that the fact of being registered in the Commercial Registry, having a Spanish NIF, and having authorization from the Bank of Spain are merely reflections of the principle of territorial unity, whose effectiveness requires certain tax and regulatory formalities to ensure compliance with the specific rules and competencies of each Member State in those aspects and areas where the competence is exclusive and not a reflection of a common competence.

In summary, it argues that the AEPD cannot act against the branch in Spain of the French company Orange Bank S.A., because the branch lacks its own legal personality that is distinct from the French company. Any action against the French company Orange Bank S.A., regardless of whether it is notified to its branch in Spain or any other office of the company, can only be carried out by the main supervisory authority.

That is to say, it considers that only the French CNIL could have acted, as it is the only interlocutor with Orange Bank S.A. regarding the cross-border processing that the company has carried out in Spain through its branch in Spain.

In conclusion, since the data processing subject to this procedure is cross-border, as the issue has arisen from the activity in Spain of a company of French nationality, Orange Bank S.A., through its branch, the only supervisory authority with the competence to act against Orange Bank S.A. is the main supervisory authority, that is, the one competent in the Member State of its main establishment.

The CNIL is the only authority that could have acted against Orange Bank S.A.

In conclusion, it asserts that the lack of competence and procedure being reported renders the actions taken by the AEPD null and void, as established by Article 47.1 of Law 39/2015.

4. On the expiration of prior actions.

It understands that the computation of the expiration period for prior actions began at the moment the Administration carried out the first material investigative action, that is, on December 23, 2022, when the AEPD requested Marktél and the telecommunications operator to provide information regarding the complaint of A.A.A. in the context of the aforementioned files.

And therefore, the prior investigative actions - EXP202213536 and EXP20221353 - expired on 23/12/2023.

It claims that the Agency had a legal obligation to declare the expiration of the file and order the archiving of the actions, as established by Article 25.1 b) of Law 39/2015.

However, the Agency has continued with the processing of a procedure that, from that moment, is affected by an indisputable cause of nullity, so that the initiation of the sanctioning file and its instruction are null.

Finally, regarding this point, it wants to highlight that the proposed resolution includes numerous arguments regarding the non-expiration of the sanctioning file, which have not been raised by this party and, therefore, have no relation to this legal discussion.

5. On the contradiction between the initiation agreement of the file and the archiving of actions dated December 28, 2022.

It states that on 28/12/2022, the Division of Technological Innovation of the AEPD notified Orange Bank S.A. Branch in Spain of the archiving of the investigation related to the reported security breach and announced that there would be no further actions regarding the reported facts (decision REGAGE22e00056805824).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/48

However, it states that the Agency has opened a sanctioning file in which it does not even formally revoke the agreement of 28/12/2022 that was beneficial to it. It considers that the notification of 28/12/2022 generates rights for Orange Bank S.A. Branch in Spain that cannot be eliminated from the legal reality based on mere formalities. And that if, upon receiving the complaints, the Agency considered that there were reasons to act against Orange Bank S.A. Branch in Spain, it should have revoked the previously stated declaration through the specific procedure established in Article 107 of Law 39/2015.

6. There is a persecutory intent of the Agency against Orange Bank S.A. Branch in Spain.

It states that the proposed resolution uses clearly biased wording to distort the image of Orange Bank S.A. Branch in Spain and thus justify the enormous amount of the proposed sanction regarding the number of affected records, the number of unmasked IBAN codes, and the lack of protection of the IBAN code.

It considers that the proposed resolution produces an image of Orange Bank S.A. Branch in Spain of absolute irresponsibility in the protection of personal data under its responsibility and of abandoning its clients' data to their fate, when in reality, Orange Bank S.A. Branch in Spain selected a top-level provider and contractually required a completely adequate level of security.

7. Size of Orange Bank S.A. Branch in Spain.

It wishes to emphasize the fact that the proposed resolution is based on a false premise by insisting on the same idea that was already present in the initiation agreement of the file: Orange Bank S.A. Branch in Spain is a large company.

It informs that the activity of Orange Bank S.A. Branch in Spain responds to very different parameters:

- (...)
- (...)
- (...) €

It claims that it has provided the Corporate Tax of the entity (Model 200) corresponding to the 2022 financial year, submitted to the AEAT (...).

8. Lack of proportionality of the proposed sanction.

It considers that the amount of the sanction sought in the proposed resolution, €1,500,000, is comparable to the fines imposed on large Spanish banks (Caixabank, BBVA) but Orange Bank S.A. Branch in Spain is infinitely smaller than these entities with more than 15 million clients.

It alleges that Orange Bank S.A. Branch in Spain has a business volume (...), as evidenced by the bank's tax returns. And that the Agency relies on a business figure that is impossible to ascertain its origin and that is not accepted by this party. That business figure is false and cannot be attributed to either Orange Bank S.A. or the Branch in Spain of Orange Bank S.A.

It states that it cannot be taken into account to calculate the amount of the sanction and, therefore, the arguments regarding proportionality made by the Agency in the proposed resolution are inadmissible. The Agency bases that alleged proportionality on figures whose origin is unknown.

9. Qualification of the infringement as very serious.

It clarifies that the infringement attributed to Orange Bank S.A. Branch in Spain arises from a failure in the security system that was in place at the time of the security breach and that, nevertheless, did not prevent it.

It considers that from the Established Facts it is undoubtedly deduced that Orange Bank S.A. Branch in Spain had established security conditions that were adequate for the risks arising from the processing of the data affected by the security breach.

It states that there is sufficient evidence in the sanctioning file that proves that Orange Bank S.A. Branch in Spain had implemented a security system that aimed to prevent what ultimately occurred and that specifically included the obligation of the service provider Marktel to maintain encrypted data, use encrypted communication channels, and establish antimalware tools in its systems.

Furthermore, as soon as Orange Bank S.A. Branch in Spain became aware that the IBAN data was stored in Marktel's systems without obfuscation, it initiated the procedures to mitigate the risk posed by the retention of the complete data, which ultimately consumed a whole year of development and implementation, but starting from November 2022, the IBANs were stored in protected systems through obfuscation. These provisions resulted in half of the data of Orange Bank S.A. Branch in Spain that suffered the consequences of the security breach being protected by this measure.

It states that Orange Bank S.A. Branch in Spain had established a security system, had assessed the risks associated with the data that suffered the consequences of the security breach, had implemented appropriate security measures by requiring the service provider to adopt adequate security measures, and had maintained a continuous system of evaluation and adjustment, so that by the middle of the service period, the risk of the unmasked IBAN had been mitigated.

It concludes that a complete lack of foresight and responsibility in the protection of data cannot be attributed to Orange Bank S.A. Branch in Spain, and therefore, it cannot be charged with the infringement of the principles of Article 5 of the GDPR.

It adds that when the data controller has properly conducted risk analyses, defined a security system, and ensured its implementation, the existence of a security breach is an event that only...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/48

may generate liability if the forecasts made and the monitoring of the implementation are insufficient.

10. Need for the resolution proposal to be adapted to the factual circumstances that have been corrected or clarified.

It indicates that the initial allegations revealed that there were certain inaccuracies in the initiation agreement of the file regarding the data on which the attribution of liability was based, and the Agency has taken these corrections into account in the initiation agreement of the file.

It claims that, in fact, the number of data subject to the liability of Orange Bank S.A. Branch in Spain is limited to 5.8% of those initially attributed.

It adds that, furthermore, it has been proven that the IBAN data was subject to obfuscation starting in November 2022.

And, finally, it has been proven that the security system implemented by Orange Bank S.A. Branch in Spain included, among other things, the encryption of the data stored in the provider's system and the implementation of anti-malware tools.

These data affect, in the opinion of Orange Bank S.A. Branch in Spain, the assessment of the liability that could be attributed to it, and therefore, this liability should be modified in the resolution proposal. However, it states that the resolution proposal maintains the initially warned sanction and does not provide any assessment or justification regarding the reasons why these changes do not influence the attribution or qualification of liability, nor the amount of the initially warned sanction.

In view of this, it requests that the document be accepted and that the procedure for allegations to the resolution proposal be considered attended to, and that, in its view, it be agreed:

1. The declaration of nullity of the file due to lack of competence.
2. Alternatively, the declaration of nullity of the proceedings from the moment the preliminary investigation proceedings expired.
3. Alternatively, the nullity of the file for infringement of the procedure for the declaration of harmfulness of acts declaring rights.
4. Alternatively, the correction in the resolution of inappropriate references to data that do not reflect the reality of this sanctioning file.
5. In addition to the previous one, the filing of the proceedings, because there are no reasons to attribute any liability to Orange Bank S.A. Branch in Spain.
6. Alternatively to the previous one, the classification of the infringement as serious and not very serious.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

17/48

7. In addition to the previous one, the adjustment of the amount of the sanction to the size and real economy of Orange Bank S.A. Branch in Spain.

8. In addition to the previous 6. and 7., the adjustment of the amount of the sanction to the actual figures of data under the responsibility of Orange Bank S.A. Branch in Spain.

In view of all that has been acted upon, the Spanish Agency for Data Protection considers the following proven facts in the present procedure,

PROVEN FACTS

FIRST: (...).

(...):

-

(...)

SECOND: On October 5, 2022, and November 4, 2022, two notifications of security breaches were received from MARKTEL with entry registration numbers REGAGE22e00044254458 and REGAGE22e00049917967.

From the content of both notifications, the following relevant information is extracted:

- Description of the breach: "(...)."
- (...).

THIRD: On October 22, 2022, and November 21, 2022, two breach notifications were received from ORANGE ESPAGNE SAU, from which the following information is extracted:

- Description: "(...)"

FOURTH: On October 28, 2022, and entry registration REGAGE22e00048666972, a notification of a security breach was received from the data controller ORANGE BANK SA (BRANCH IN SPAIN) with the following highlighted information:

- Description: "(...)"

FIFTH: (...):

☐

(...)

☐

(...)

☐

(...)

☐

(...)

☐

(...)

☐

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/48

(...).

SIXTH: Regarding the responsibility for the leaked personal data, it has been established that MAKTEL acted as a subcontracted data processor for ORANGE ESPAGNE by providing the service of recovering unpaid debts from customers who acquired debts through the purchase of terminals on credit. ORANGE ESPAGNE acted with a dual role concerning this data, on one hand, as the data controller of the personal data provided during the purchase, and on the other hand, as a data processor, among others, for ORANGE BANK, given that there was a transfer of credit rights for the debts incurred in the installment sale of the terminal, with ORANGE ESPAGNE being responsible in the contract for managing the recovery operations in case of non-payment.

SEVENTH: On July 1, 2020, ORANGE and ORANGE BANK signed a service provision contract which expressly states that MERKEL is subcontracted by ORANGE. It is also noted in the section on commitments regarding the processing of personal information that "Whenever personal data is processed, the Assignor will comply with the conditions set forth in the contract, as well as all applicable data protection regulations at any given time. In the event that the Assignor acquires, by virtue of the contract, the status of Data Processor of personal data, it will ensure, taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of individuals, that it will apply appropriate technical and organizational measures to ensure a level of security appropriate to the risk.

In evaluating the adequacy of the level of security, particular consideration will be given to the risks presented by the data processing, particularly as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, in accordance with the provisions of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, on the protection of individuals with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (hereinafter, GDPR).

Furthermore, the Assignor will provide the contact details of the Data Protection Officer of Orange."

EIGHTH: ORANGE ESPAGNE signed a data processor contract with MARKEL retroactively effective from January 1, 2022, which incorporates the subject matter of the data processing assignment, the affected personal data, the categories of data subjects, the obligations assumed by the processor, and the security measures.

In this contract, Clause 17 regarding data protection establishes concerning security measures in section 2.6.d) that:

(...):

-

(...)
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

19/48

-

(...)

-

(...)

-

(...)

-

(...).

ANNEX III

SPECIFIC MEASURES REGARDING INFORMATION SECURITY AND CODE OF CONDUCT FOR SUPPLIERS AND FRAUD CONTROL AND REVENUE ASSURANCE

(...)

(...)

NINTH: Regarding compliance with the notification obligations of the breach both to this Agency and to the affected parties, the following chronology of events has been established:

-

(...)

-

(...)

-

(...)

-

(...)

-

(...)

TENTH: The implementation of the following list of preventive measures by MARKTEL prior to the incident has been confirmed:

-

(...)

-

(...)

-

(...)

-

(...)

-

(...)

-

(...)

-

(...)

-

(...)

-

(...)

-
(...)

-
(...)

-
(...)

ELEVENTH: The implementation and deployment of the following list of reactive measures adopted by MARKTEL has been confirmed:

-
(...)

-
(...)

-
(...).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
20/48

-
(...)

-
(...)

-
(...)

-
(...)

TWELFTH

: In relation to the clients affected by the breach whose data was the responsibility of ORANGE BANK (following the assignment of credit rights from ORANGE ESPAGNE), it has been established that these clients were informed of this assignment of credits in the purchase invoice itself, including a text at the bottom of the invoice with the following information:

- That ORANGE BANK is responsible for the credit rights of the incurred debt and for their personal data.
- That ORANGE BANK had delegated the collection management to ORANGE ESPAGNE itself.
- The existence of data protection rights and how to exercise them.
- An email address for obtaining additional information.

THIRTEENTH: From the responses provided by ORANGE BANK to this AEPD with entry records REGAGE23e00004368876 and REGAGE23e00039958481, it is inferred that ORANGE ESPAGNE notified the incident to ORANGE BANK on October 25, 2022, (...).

(...)

LEGAL GROUNDS

I Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, in so far as they do not contradict them,

subsidiarily by the general rules on administrative procedures."

II Preliminary Issues

ORANGE BANK S.A: is a company in the financial sector that, in the exercise of its professional activity, processes a large amount of personal data,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/48

understanding personal data as: "any information relating to an identified or identifiable natural person."

It carries out the processing activity in which the breach of personal data security occurred in its capacity as data controller, as it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR:

"data controller" or "controller": the natural or legal person, public authority, agency, or other body that, alone or jointly with others, determines the purposes and means of the processing; if the law of the Union or of the Member States determines the purposes and means of the processing, the controller or the specific criteria for its designation may be established by the law of the Union or of the Member States.

An identifiable natural person is considered to be one whose identity can be determined, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that person.

Furthermore, processing should be understood as "any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination, or any other form of enabling access, comparison or interconnection, restriction, erasure, or destruction."

Article 4, paragraph 12 of the GDPR defines "personal data breach" as any breach of security that results in the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data transmitted, stored, or otherwise processed.

In this case, and as a result of the investigation carried out following the notification of the personal data security breach under the circumstances mentioned above, possible violations of data protection regulations have been detected.

The breach is categorized as a confidentiality breach, as unauthorized access to the processed personal data was confirmed.

Marktel Global Services S.A. (Marktel), a subcontractor of ORANGE BANK, suffered an attack in which personal data was affected. (...)

Regarding the responsibility for the leaked personal data, it has been established that MARKTEL acted as a data processor for ORANGE ESPAGNE by providing the service of recovering unpaid debts from customers who incurred debts from the purchase of devices on credit. However, ORANGE ESPAGNE acted with a dual role concerning this data, on one hand, as the data controller of the personal data provided at the time of purchase, and on the other hand, as a data processor for ORANGE BANK due to the assignment of rights from

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/48

credits for debts incurred in the installment sale of the terminal, entrusting ORANGE ESPAGNE with the management of recovery operations in case of non-payment.

III Response to the allegations regarding the initiation agreement

In response to the allegations presented by the investigated entity, the following should be noted:

- **Expiration of prior proceedings.**

Regarding the possible expiration of prior proceedings that the investigated entity mentions in its allegations to the initiation agreement, it should be indicated that the claims that give rise to the present procedure were admitted for processing on February 18 and 28, 2023, and that the present procedure was initiated on February 16, 2024, therefore before the lapse of the 12-month period established by the LOPDGDD for the expiration of investigative proceedings.

Notwithstanding the above, it should also be noted that the expiration period for the present procedure is computed from the date on which its initiation is agreed, that is, from February 27, 2024, making it inappropriate to add any other period to that computation, for the purposes of measuring the duration of the administrative file, such as the time of the prior investigative proceedings, or the time that elapses between the conclusion of those proceedings and the opening of the procedure, nor the time corresponding to the admission phase of the claims presented.

Our Supreme Court has repeatedly declared this. In the Judgment of 21/10/2015, the Judgment of 26/12/2007 (appeal 1907/2005) is cited, which states the following:

"[...] the period of the procedure [...] is counted from the initiation of the sanctioning file, which obviously excludes from the computation the time of the reserved information;" "[...] the greater or lesser duration of the preliminary phase does not entail the expiration of the subsequent procedure."

Also, in the Judgment of the Supreme Court of 13/10/2011 (appeal 3987/2008) that examines a ground for cassation related to the computation of the expiration period of the procedure, it states the following:

"We cannot share the reasoning presented by the lower court to set a different starting point than that established by the Law, indicating as the initial date for the computation the day following the conclusion of the preliminary informative proceedings.

[...]

Well, once those preliminary proceedings have been carried out, the time it takes the Administration to agree to initiate the procedure [...] may have the consequences that are appropriate regarding the computation of the prescription (extinction of the right); but it cannot be taken into consideration for the purposes of expiration, since this figure aims to ensure that once the procedure is initiated, the Administration does not exceed the time limit it has to resolve. In the third ground of the contested judgment, the lower court makes an interpretation of the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/48

a rule that is not in accordance with the nature of the institution of expiration, since unlike prescription, which is a cause for the extinction of the right or responsibility in question, expiration is a means of terminating the procedure due to the passage of the period established in the rule, so its assessment does not prevent, if the period established for the prescription of the action for the restoration of urban legality by the Administration has not elapsed, the initiation of a new procedure."

Thus, the argument that the investigated entity presents on this matter in its allegations does not conform to the law.

□

Lack of passive legitimacy of Orange Bank Branch in Spain and lack of territorial competence of the AEPD.

Regarding the lack of passive legitimacy of Orange Bank Branch in Spain and the lack of territorial competence of the AEPD, we must point out that this Data Protection Agency has accessed the Interactive Commercial Information of the Commercial Registries of Spain to obtain information about the entity ORANGE BANK SA BRANCH IN SPAIN, (...). Therefore, it has its own legal personality. Consequently, this Agency considers not only the direct responsibility of ORANGE BANK SA BRANCH IN SPAIN in the facts for which the AEPD is competent to sanction, but also that the entity has

sufficient prerogatives to decide on the treatments carried out in Spain for its clients and, therefore, such treatments fall within the competence of the Spanish Data Protection Agency.

□

Contradiction between the initiation agreement of the file and the document of December 28, 2022. In the heading of the document of December 28, 2022, cited by ORANGE BANK, it states "DIVISION OF TECHNOLOGICAL INNOVATION" and concludes by indicating that this Division does not have any further actions planned.

Therefore, contrary to what the investigated entity claims, this document does not have a decisive character, neither due to its content (it is rather an "acknowledgment of receipt" of the reported breach and cannot be understood in any way as if this AEPD had assessed that there was no responsibility for a supposed breach of data protection regulations, which would imply the filing of actions - as the entity has wanted to understand) nor by its form, since it does not even formally reflect a decision, much less a resolution to file any action, as for that to be the case it is necessary that such actions have been initiated.

This document is aimed at informing ORANGE BANK of the receipt of the notification of the breach that occurred and its incorporation into the breach notification register, in accordance with the provisions of Article 31.d) of the Agency's Statute, approved by Royal Decree 389/2021, of June 1, without it being inferred from it that the AEPD assessed and decided that there was no responsibility for a supposed breach of data protection regulations. It only informs that no further actions will be carried out by the DIT, but all this without prejudice to the possibility of initiating other actions, as is obvious.

Thus, Article 13 of the AEPD Statute determines the functions of the Presidency:

1. It is the responsibility of the Presidency of the Spanish Data Protection Agency:

d) To issue the resolutions and guidelines required for the exercise of the Agency's functions, particularly those arising from the exercise of the powers provided for in Article 57 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, and from the exercise of the investigative powers and corrective powers provided for in Article 58 of the aforementioned Regulation.

Article 57, Functions, of the GDPR in its letter h) establishes that:

"1. Without prejudice to other functions under this Regulation, it shall be the responsibility of each supervisory authority, in its territory:

(...)

h) to carry out investigations into the application of this Regulation, in particular based on information received from another supervisory authority or another public authority;

(...)

Regarding the functions of the General Subdirectorate of Data Inspection of the AEPD, Article 27 of the Agency's Statute indicates, in its section 1, that

"The General Subdirectorate of Data Inspection is the administrative body, dependent on the Presidency of the Spanish Data Protection Agency, that develops the competencies provided for in Article 57.1, letters f), g), h), i) and u) of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, and carries out the inspection and instruction functions necessary for the exercise of the investigative powers established in Article 58.1, letters a), b), d), e) and f) and the corrective powers provided for in Article 58.2, letters a), b), c), d), f), g), i) and j), both of the aforementioned Regulation."

And in section 2 of this Article 27, it enumerates the functions corresponding to the General Subdirectorate of Data Inspection, among which, for the purposes of this document, are the following:

"a) The ongoing supervision of compliance with Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, of Organic Law 3/2018, of December 5, and of the provisions that develop it, by the controllers and processors of the treatments.

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

b) The exercise of the investigative powers defined in Article 51 of Organic Law 3/2018, of December 5.

(...)

d) The processing of procedures in the event of a possible violation of data protection regulations in accordance with the provisions of Title VIII of Organic Law 3/2018, of December 5, including citizens' complaints for lack of attention to their requests for the exercise of the rights set forth in Articles 15 to 22 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016. It is the responsibility of the General Sub-Directorate for Data Inspection to inform the complainant about the course and outcome of the complaint submitted to the Spanish Agency for Data Protection, in accordance with the provisions of Article 77.2 of the aforementioned Regulation.

(...)

Therefore, to proceed with the filing of investigative actions, it is required, first, that they have been initiated (either by admitting a complaint for processing or by the agency's own initiative, which in both cases requires an express resolution signed by the Director), which had not occurred at the time the aforementioned letter from the Division of Technological Innovation (DIT) was issued, and, second, an express resolution from the Director was necessary, archiving said actions because it was understood, now indeed, that from the information gathered in said investigations, the existence of a violation of data protection regulations was not concluded, which had not occurred.

In the present case, two complaints were submitted by individuals affected by the breach, which were admitted for processing by the AEPD in February 2023 in compliance with Article 64 of the LOPDGDD. Article 64. Form of initiation of the procedure and duration.

1. When the procedure refers exclusively to the lack of attention to a request for the exercise of the rights established in Articles 15 to 22 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, it will be initiated by an admission agreement, which will be adopted in accordance with the provisions of Article 65 of this organic law.

In this case, the deadline for resolving the procedure will be six months from the date on which the complainant was notified of the admission agreement. After this period, the interested party may consider their complaint accepted.

2. When the procedure aims to determine the possible existence of a violation of the provisions of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, and this organic law, it will be initiated by an initiation agreement, adopted on its own initiative or as a result of a complaint, which will be notified to the interested party.

If the procedure is based on a complaint filed with the Spanish Agency for Data Protection, prior to this, it will decide on its admission for processing, in accordance with the provisions of Article 65 of this organic law.

Once the complaint is admitted for processing, as well as in cases where the Spanish Agency for Data Protection acts on its own initiative, prior to the initiation agreement, there may be a phase of preliminary investigative actions, which will be governed by the provisions of Article 67 of this organic law.

The procedure will have a maximum duration of twelve months from the date of the initiation agreement. After this period, it will expire, and consequently, the actions will be archived.

In relation to the preliminary investigative actions, Article 67 of the LOPDGDD provides the following: Article 67. Preliminary investigative actions.

1. Before adopting the initiation agreement of the procedure, and once the complaint has been admitted for processing if there is one, the Spanish Agency for Data Protection may carry out preliminary investigative actions in order to achieve a better determination of the facts and circumstances that justify the processing of the procedure.

The Spanish Agency for Data Protection will act in any case when it is necessary to investigate treatments that involve massive traffic of personal data.

2. The preliminary investigative actions will be subject to the provisions of Section 2 of Chapter I of Title VII of this organic law and may not last longer than eighteen months from the date of the

admission agreement or from the date of the agreement by which its initiation is decided when the Spanish Agency for Data Protection acts on its own initiative.

From this regulation, it is not inferred in any way that the AEPD must justify in the manner required for the initiation of preliminary actions. The preliminary investigative actions are carried out to clarify the facts and circumstances of what happened, gathering more information in order to determine the existence or not of a possible violation of data protection regulations.

In this sense, the initiation of preliminary investigations and their execution, a power of the AEPD with or without complaints, does not prejudice anything, but allows for the gathering of the necessary information to determine whether there are indications of a violation or not. Even after such an investigation, it may be that the actions are archived because it is understood, in light of the information gathered, that the necessary elements for the...

27/48

Opening of a sanctioning procedure. This has not occurred in the present case.

What the regulations indicate is that, after the submission of complaints, this Agency must decide whether to admit them for processing or not, having ultimately decided to admit them. And, as indicated in article 67.2 of the LOPDGDD referenced, the AEPD may carry out preliminary investigative actions. This occurred in this case, in order to achieve a better determination of the facts and circumstances. It is a power assigned to the AEPD by the GDPR and by the LOPDGDD. Furthermore, to elaborate further, even in the event that the complaints had not existed, the questioned document would not have been an impediment or obstacle to the exercise of the investigative powers that the AEPD has in accordance with the aforementioned article 64.2, which states that "Once the complaint is admitted for processing, as well as in cases where the Spanish Data Protection Agency acts on its own initiative, prior to the initiation agreement, there may be a phase of preliminary investigative actions."

Therefore, the present sanctioning procedure has not been initiated due to the content or any new information provided in the two complaints submitted to this AEPD, but rather due to the information and documentation obtained after the period of preliminary investigative actions, from which possible violations of data protection regulations can be inferred.

In this regard, it is reiterated that such complaints are only admitted if the documentation and everything collected during those investigative actions is what has exclusively motivated the initiation of the present sanctioning procedure, and not the aforementioned complaints.

□

ORANGE BANK is a victim of a crime.

In this regard, it should be noted that the culpability of the acting party cannot be considered excluded or mitigated by the fact that there has been fraudulent action by a third party, as the responsibility of the acting party does not derive from the actions of this third party, but from their own actions.

In no case has total infallibility of the measures that can be adopted to ensure adequate protection in the processing of personal data been required. (...)

(...)

(...)

ORANGE BANK is responsible for the processing of this data and consequently responsible for ensuring that the data processed on its behalf has the necessary security guarantees to prevent or hinder a loss of confidentiality, integrity, or availability of the data, which did not occur in this case as the data was found unencrypted.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/48

□

Absence of culpable or negligent conduct by ORANGE BANK.

As for the fact that almost all files initiated by this Agency regarding security breaches resulting from a ransomware cyberattack have been archived, it is noted that, in addition to highlighting that this type of

attack is commonplace and therefore largely foreseeable, each attack is different because, even if the attack were similar, the companies that suffer it are distinct, with different and specific personal data processing, and in each case, the existing security measures must be analyzed (whether they existed, whether they were adequate to ensure an appropriate level of security relative to the specific risk in each case, whether they were effective, whether they were observed, etc.).

In terms of data protection, the technical and organizational measures to be adopted by the data controllers and other obligations to be fulfilled as required by the GDPR must be appropriate in relation to the specific risks posed by the specific processing carried out by each controller. Therefore, when analyzing the diligence of each party in complying with the regulations, the circumstances of each specific case must be taken into account, considering the nature, scope, context, and purposes of each processing, thus there are no identical cases.

The jurisprudence is clear on this matter. Thus, the Judgment of the National Court of April 28, 2023 (SAN 28.04.2023 REC. 409/2021) indicates that "It refers to a discriminatory sanctioning treatment since that fine or economic sanction can be replaced by the measures of art. 58 GDPR, less burdensome measures such as a warning. And it refers to other infringements committed by other entities. Of course, the plaintiff tries to compare this situation with another sanctioning procedure mentioned, but we are not facing discriminatory treatment or a violation of the principle of equality since it is a principle that only operates within the framework of legality when identical factual situations are treated differently without reasonable justification. As stated in the STS of January 20, 2004, "equality must be asserted within legality, so that if the correct action of the Administration is the one now being judged, as we have declared, the one invoked as contrary to it was not, and therefore cannot be invoked to demand that the appellant be treated equally, since, as this Chamber of the Supreme Court has stated in its judgments of June 16, 2003, July 14, 2003, and October 20, 2003, 'the principle of equality lacks significance to protect a situation contrary to the legal order,' and this, as the very sentencing Chamber indicates, regardless of the fact that the alleged administrative action contradicting the present has not been substantiated."

□

(...)

In this regard, it is noted that the breach of confidentiality attributed to it is the one that corresponds to it, that is, for failing to comply with the obligation imposed in Article 5.1.f) to process the data in such a way as to ensure an adequate level of security, including protection against unauthorized or unlawful processing, through the application of appropriate technical or organizational measures. The loss of control over one's own personal data occurs from the moment the personal data breach materializes, that is, from the moment that access occurs.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/48

by an unauthorized third party to personal data. This is the loss of confidentiality attributed to you.

There are measures specifically aimed at ensuring the confidentiality of personal data, (...).

In this regard, it is pertinent to bring to attention the Judgment of June 22, 2021 - Rec. 1210/2018, and the Judgment of November 5, 2011 - Rec. 1796/2019 in which the Chamber, evaluating the subjective or culpability element, "...insisting that the culpability of the plaintiff cannot be considered excluded or mitigated by the fact that there may have been fraudulent action by a third party, since the responsibility of the plaintiff does not derive from the actions of this party, but from their own."

□

Inadmissibility of objective liability and diligence and adequacy of the measures adopted and implemented by ORANGE BANK

It should be noted that in no case has total infallibility of the measures that can be adopted to ensure adequate protection in the processing of personal data been required. However, once the attack has occurred, the diligence of those responsible and in charge must be evaluated in the application of appropriate technical and organizational measures to ensure a level of security adequate to the risk,

taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing. In the present case, the loss of confidentiality was confirmed as a consequence of the exfiltration of the data.

In this regard, it should be noted that neither Article 5.1(f) nor Article 32 of the GDPR refer solely to information security or cybersecurity measures aimed at preventing cyberattacks, but to the obligation to apply appropriate technical and organizational measures to ensure a level of security adequate to the risk that includes, among others, the ability to ensure the confidentiality, integrity, availability, and permanent resilience of the processing systems and services and the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident. All of this must take into account the state of the art, the costs of implementation, and the nature, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons.

Furthermore, the second paragraph of the aforementioned Article 32 indicates that when assessing the adequacy of the level of security, particular attention will be paid to the risks presented by the processing of data, particularly as a result of the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the communication or unauthorized access.

That is to say, the GDPR establishes the obligation that personal data be processed in such a way as to ensure their confidentiality, integrity, and availability, and for this, it is necessary to assess the risks and, based on them, adopt appropriate measures to avoid them or mitigate their impact on the rights and freedoms of natural persons.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
30/48

In the present case, as previously noted, MARKTEL suffered a ransomware attack, resulting in a security breach consisting of a breach of confidentiality and availability, as unauthorized access to the personal data processed was confirmed, which had been encrypted by the attacker.

Therefore, considering that attacks are foreseeable (and not all are inevitable), mechanisms must be in place to ensure the confidentiality of the data.

Thus, it must be acknowledged that preventive mechanisms hardly guarantee total data security against certain sophisticated attacks and, consequently, must be based on the assessment of measures that can mitigate the impact and allow for an adequate response in the event of risk materialization.

As previously indicated, there are measures specifically aimed at ensuring the confidentiality of personal data, (...).

☐ Responsibility of the data processor.

Regarding the responsibility for the leaked personal data, it has been established that MARKTEL acted as a sub-processor by providing the service of recovering unpaid debts from ORANGE BANK customers who acquired debts from the purchase of terminals on credit. ORANGE ESPAGNE acted with a dual role concerning this data, on one hand, as the data controller of the personal data provided during the purchase, and on the other hand, as the data processor for ORANGE BANK SA due to the assignment of credit rights from the debts incurred in the installment sale of the terminal, entrusting ORANGE ESPAGNE SAU with the management of recovery operations in case of non-payment. Therefore, ORANGE BANK SA is responsible for the credit rights of the incurred debt and for its personal data. This is irrespective of the actions and responsibility that third parties may have incurred, as the negligence or illegal actions of third parties do not exclude their own.

☐ Lack of proportionality of the proposed sanction.

It should be noted that Article 83.1 of the GDPR states that “Each supervisory authority shall ensure that the imposition of administrative fines in accordance with this Article for the infringements of this Regulation referred to in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate,

and dissuasive.”

Fines, therefore, as deduced from the invoked provision, must be effective, proportionate, and dissuasive to achieve the purpose intended by the GDPR.

It is true that for this system to function with all its guarantees, several elements must be deployed in an integral and complete manner. The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the Spanish case as permitted by the GDPR itself - would undermine the effectiveness of the system, losing its

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

31/48

meaning, its teleological purpose, the will of the legislator, resulting in fines imposed for different infractions ceasing to be effective, proportionate, and deterrent. In this way, interested parties would also be deprived of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

The GDPR is endowed with its own principle of proportionality that must be applied in its strict terms. Regarding the principle of proportionality of sanctions, the National Court has indicated in numerous rulings that the principle of proportionality cannot be exempt from judicial review, as the margin of appreciation granted to the Administration in imposing sanctions within the legally established limits must be developed by weighing, in any case, the concurrent circumstances, in order to achieve the necessary and due proportion between the alleged facts and the responsibility required, given that every sanction must be determined in accordance with the severity of the infringement committed and according to a criterion of proportionality in relation to the circumstances of the act. Thus, proportionality constitutes a normative principle that is imposed on the Administration and that reduces the scope of its sanctioning powers.

Well, in accordance with the circumstances present in this case, which have been meticulously and appropriately evaluated, this resolution does not violate the principle of proportionality in determining the imposed sanction, resulting in a measured and proportionate response to the severity of the infringement committed, the importance of the facts, as well as the circumstances taken into account to grade the sanction, without any reasons being appreciated that further justify the reduction made, especially considering the amount to which such sanctions may rise in accordance with Article 83.5 of the GDPR, which provides for an infringement of Article 5.1(f) of the GDPR, “with administrative fines of up to €20,000,000 or, in the case of an undertaking, an amount equivalent to 4% of the total global annual turnover of the previous financial year, opting for the higher amount.”

□ The nature, gravity, and duration of the infringement (Article 83.2(a) of the GDPR).

In this regard, it should be noted that such considerations cannot be admitted as mitigating factors or as circumstances that diminish the severity of the facts; rather, the opposite is true, as precisely due to the high number of processing activities carried out and the clients affected, the investigated entity is obliged to act with the special diligence that must be required of an entity of these characteristics, which carries out numerous personal data processing activities. The considerable number of affected individuals from the personal data breach cannot be overlooked.

(...).

It is worth recalling the Judgment of the National Court of 17/10/2007 (rec. 63/2006), which regarding entities whose activity involves the continuous processing of customer data, states, “...the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the...

32/48

The infringer does not behave with the required diligence. In assessing the degree of diligence, special consideration must be given to the professionalism or lack thereof of the individual, and there is no

doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it is necessary to emphasize the rigor and exquisite care to comply with the legal provisions in this regard.

In the case at hand, the type of data being processed and that was affected by the breach, which ORANGE BANK seems to disregard, poses a high risk, in the event of a breach of its confidentiality, of being used fraudulently: identity theft, phishing, financial fraud, etc.

What is intended to be highlighted is that the infringement of Article 5.1.f) affects one of the basic principles on which the regulations on personal data protection are based, confidentiality, and this violation is exacerbated and aggravated by the number of individuals affected by the incident, the damages and losses caused (irreversible loss of power and control over personal data by the clients).

– Intentionality or negligence in the infringement (Article 83.2.b) of the GDPR).

The fact that ORANGE BANK is a company whose activity involves constant and abundant handling of personal data, carrying out processing that entails a probable high risk to the rights and freedoms of individuals, implies a greater requirement for diligence in the processing of personal data than what could be required of a small company that conducts sporadic or ancillary processing.

Considering that the conduct of the investigated entity includes the element of culpability, which is essential to impose sanctioning responsibility, in this case, it is also specified in a very serious lack of diligence in complying with the principle of confidentiality of personal data, as has been demonstrated throughout the procedure.

(...)

– The link between the business activity of the defendant and the processing of personal data of clients or third parties (Article 83.2.k of the GDPR in relation to Article 76.2.b of the LOPDGDD).

The aggravating factor provided for in Article 76.2.b) of the LOPDGDD applies when the infringer's activity is linked to the processing of personal data, and it is obvious that, in relation to the present data controller, its activity, in this specific banking case, is clearly linked, directly, to multiple processing of personal data affecting thousands of clients.

In this regard, the National Court has considered it correct to appreciate the aggravating factor provided for in Article 76.2.b) of the LOPDGDD whenever the aforementioned link exists, and it has considered this in numerous judgments, including one dated 04/07/2024 (rec. 382/2022), which states regarding the cited circumstance that:

“As well, the aggravating factor of the continued nature of the infringement, as set out in Article 76.2.a) of Organic Law 3/2018, of December 5, is also applicable.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

33/48

Protection of Personal Data and Guarantee of Digital Rights, referring to the application of the GDPR to the infringement at hand. Likewise, the assessment of the link between the infringer's activity and the processing of personal data (Article 72.2.b) of Organic Law 3/2018, of December 5), is due to the fact that the activity of the appellant is linked to the processing of data from both clients and third parties; this link is well-known as the entity, due to its activity, is in constant contact with clients and third parties handling a large volume of data, which imposes a greater duty of diligence” (the emphasis is ours).

□

Mitigating Circumstances

In this regard, it should first be noted that the requirements of the AEPD are mandatory.

Therefore, in this case, the degree of cooperation with the Agency cannot be appreciated and the mitigating circumstance cannot be applied, since the consideration of cooperation with the Agency as a mitigating factor, as the entity intends, is not linked to any of the situations in which legal collaboration or cooperation or response to a requirement is legally provided. Therefore, when the actions are due and required by law, as in the case at hand, their application is not appropriate.

In the present case, the circumstances of the case have been taken into account: the severity of the infringement, the consequences thereof, the lack of diligence shown, the specific processing carried out, the type of personal data, and the number of affected individuals, the circumstances of the company (size, business volume, etc.), all of which are highlighted and motivated in the Agreement to Initiate this sanctioning procedure and are reproduced in this proposal, which allows us to conclude that the principle of proportionality has been respected when determining the amount of the fine ultimately imposed.

Consequently, the allegations must be dismissed, emphasizing that the arguments presented do not undermine the essential content of the infringements declared committed nor do they constitute sufficient justification or exculpation.

IV Response to the Allegations to the Resolution Proposal

In relation to the allegations made against the Resolution Proposal of this sanctioning procedure, we proceed to respond to them in the order presented:

1. New arguments of the resolution proposal.

In relation to the statements made by Orange Bank S.A. Branch in Spain, which reproduce the allegations made throughout the sanctioning procedure, it should be noted that they were already analyzed in detail and dismissed in the Legal Grounds of the Resolution Proposal, which is transcribed in Legal Ground III of this Resolution, to which, for the sake of procedural economy, we refer.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

34/48

2. In relation to the facts.

2.1 Number of data affected by the security breach.

In this regard, it should be clarified that from the same incident (cyberattack), not only the personal data of Orange Bank S.A. Branch in Spain were affected, but also, by accessing the systems of MARKTEL, data from other companies were affected.

(...):

- (...)

(...)

In this sense, it is clarified that the impact on personal data of clients not belonging to Orange Bank S.A. Branch in Spain is not part of this sanctioning procedure, which is exclusively aimed at examining the conduct of Orange Bank S.A. Branch in Spain, as it is not responsible for the personal data of affected clients belonging to other companies, nor for the possible failure to adopt adequate measures for their protection.

Therefore, it is emphasized that the management carried out by Orange Bank S.A. Branch in Spain has been analyzed independently, without it being held accountable for possible breaches of data protection regulations that other companies may have incurred.

The fact that the total number of records affected by the cyberattack has been noted does not affect its responsibility nor does it cause any defenselessness, as it is fully aware of the facts attributed to it, the infringement that they imply, their classification, the responsibility incurred, as well as that it has had and has the opportunity to make allegations and present any documentation it deems appropriate in defense of its interests as allowed by the applicable legislation.

2.2 Number of data declared by Orange Bank S.A. Branch in Spain.

In this regard, it should be noted that the notification to the supervisory authorities of the breach of security of personal data is an obligation imposed on the data controller by the GDPR (Article 33), that is, its observance is mandated by legal imperative, it is a mandate that must be fulfilled, so its non-compliance by the controller, in accordance with what is required in that provision, may constitute an infringement of the GDPR.

Therefore, compliance with the obligation imposed on the controller cannot be appreciated to mitigate the responsibility attributed to Orange Bank S.A. Branch in Spain, as it is a duty required by law.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
35/48

2.3 Unobfuscated IBAN numbers.

(...)

(...)

In this regard, it should be noted that the alleged circumstance cannot be considered as a mitigating factor or as a circumstance that diminishes the severity of the facts, since it has never been deemed responsible for all the published data. Precisely because of the high number of data processing activities it conducts and the clients affected, Orange Bank S.A. Branch in Spain is obliged to act with the special diligence that must be required of an entity of these characteristics, which carries out numerous personal data processing activities.

It is worth recalling the Judgment of the National Court of 17/10/2007 (rec. 63/2006), which regarding entities whose activity involves the continuous processing of customer data, indicates that "...the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

In the case at hand, the type of data being processed and that was affected by the breach, which Orange Bank S.A. Branch in Spain seems to disregard, poses a high risk, in the event of a breach of its confidentiality, of being used fraudulently: identity theft, phishing, financial fraud, etc.

3. On the incompetence of the Spanish Data Protection Agency.

In this regard, it should be noted that this assertion regarding the incompetence of the Spanish Data Protection Agency was already raised against the Initiation Agreement and was responded to by this Agency in the Proposal for resolution, to which reference should be made.

In that Proposal, it was clarified its status as the data controller of the data it processes in Spain. This Agency considers the direct responsibility of ORANGE BANK S.A. BRANCH IN SPAIN in the facts for which the AEPD is competent to sanction.

As previously indicated, the entity has sufficient prerogatives to decide on the purposes and means of the processing carried out in Spain concerning its clients, and therefore, such processing falls within the jurisdiction of the Spanish Data Protection Agency.

For processing to be cross-border, it will be necessary to meet one of the conditions expressed in Article 4.23 of the GDPR:

- The processing of personal data is carried out in the context of the activities of establishments in more than one Member State of a controller or processor in the Union when the controller or processor is established in more than one Member State; or
- The processing of personal data is carried out in the context of the activities of a single establishment of a controller or processor in the Union, but that substantially affects or is likely to substantially affect data subjects in more than one Member State.

In this case, the processing is carried out exclusively on behalf of ORANGE BANK branch in Spain, which contracted with ORANGE ESPAGNE and this in turn with MARKEL, and is conducted exclusively regarding data subjects in Spain.

Therefore, none of the conditions that allow considering a cross-border processing apply.

In the case being examined, we are faced with a national processing exclusively under the jurisdiction of the Spanish Data Protection Agency and must therefore be handled as determined by Article 55 of the GDPR. The processing is carried out in the context of activities of ORANGE BANK, with an establishment in Spain and only affects data subjects in Spain; consequently, the Spanish Data Protection Agency is fully competent to process the present sanctioning procedure.

4. On the expiration of prior proceedings.

As previously stated, the complaints that give rise to the present procedure were submitted on November 18 and December 9, 2022, and were admitted for processing on February 18 and 28, 2023, within the three-month period established in Article 65.5 of the LOPDGDD. The present procedure was initiated on February 16, 2024, therefore before the expiration of the 12-month period, counting from the date of the admission agreement, established by Article 67.2 of the LOPDGDD for the expiration of investigative proceedings, in its current wording.

Thus, Article 6.5 of the LOPDGDD provided:

“5. The decision on the admission or inadmissibility for processing, as well as the one that determines, if applicable, the referral of the complaint to the main supervisory authority deemed competent, must be notified to the complainant within three months. If this notification does not occur after this period, it will be understood that the processing of the complaint continues in accordance with the provisions of this Title from the date on which three months have elapsed since the complaint was received by the Spanish Data Protection Agency.”

Regarding the prior investigative proceedings, Article 67 of the LOPDGDD established the following: Article 67. Prior investigative proceedings.

1. Before the adoption of the initiation agreement of the procedure, and once the complaint has been admitted for processing, if there is one, the Spanish Data Protection Agency

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

37/48

may carry out preliminary investigative actions in order to achieve a better determination of the facts and circumstances that justify the processing of the procedure.

The Spanish Agency for Data Protection will act in any case when it is necessary to investigate treatments that involve massive traffic of personal data.

2. The preliminary investigative actions shall be subject to the provisions of Section 2 of Chapter I of Title VII of this organic law and may not exceed a duration of twelve months from the date of the admission agreement or from the date of the agreement deciding its initiation when the Spanish Agency for Data Protection acts on its own initiative or as a result of the communication sent to it by the supervisory authority of another Member State of the European Union, in accordance with Article 64.3 of this organic law. (the underlining is ours)

Therefore, the approach that the investigated entity takes on this issue in its allegations does not conform to the law.

5. On the contradiction between the initiation agreement of the file and the closure of actions of December 28, 2022.

In the proposed resolution, it was also responded to and argued about the erroneous interpretation that Orange Bank S.A. Branch in Spain made regarding the content and nature of the DIT document, which can in no case be considered a decision to close actions.

Well, the aforementioned document does not have the decisive and resolute character that it claims, neither by its content nor by its form, and this does not hinder nor can it prevent in any way the investigative power that the AEPD has and its exercise through the inspection and investigation functions assigned to the General Subdirectorate of Data Inspection. Above all, after the submission of complaints by affected individuals, which the LOPDGDD requires to be processed.

We must indicate that the AEPD has been assigned, by virtue of Articles 57 and 58 of the GDPR, investigative functions, as appropriate, regarding the complaints submitted for this purpose.

In the case now examined, the AEPD, after conducting the appropriate investigations and in relation to a series of specific facts that it considers proven, categorizes them within the infringing type that it deems appropriate, in accordance with the application and interpretation of the regulations, providing a detailed and sufficient justification for such action. And it is that the AEPD, like the rest of the public authorities, is bound by the principle of legality (Article 9.1 and 9.3 of the Constitution -CE-) which implies the application and interpretation of the norms taking into account the specific factual situation that occurs in each case.

The AEPD has justified with a succinct reference to facts and legal grounds, as required by Article 35.1.h) of the LPACAP, the basis of its decision.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
38/48

Furthermore, it has guaranteed the rights provided for in articles 64.2.f) and 89.2 of the LPACAP, among which is the right to make allegations, so it cannot claim defenselessness. It has been able to allege and provide everything it deemed appropriate to the procedure, without any limitation from the AEPD. All allegations made in this regard have already been considered and responded to.

It is reiterated that the filing of proceedings requires a resolution that expressly and duly archives the investigative proceedings initiated in accordance with article 67 of the LOPDGDD, which has not occurred in this case.

6. There is a persecutory intent from the Agency against Orange Bank S.A. Branch in Spain. In this regard, several nuances should be made.

Firstly, the exercise of the sanctioning power has been carried out following an administrative procedure, accompanied by the necessary guarantees, and has led to the determination of the Facts, proof of guilt, and the grading of the administrative response. This grading has not been done without considering the concurrent circumstances, but rather as a manifestation and requirement of the principle of transparency (article 3.1.c) LRJSP) and the right to good administration (article 41 of the Charter of Fundamental Rights of the EU), with the facts being treated impartially and equitably, motivating the final decision at all times.

Therefore, the Agency has limited itself to analyzing the circumstances of the specific case in order to identify the existence of indications or evidence (or not) of infringement within its jurisdiction. As a consequence, it has considered it proven that Orange Bank S.A. Branch in Spain has violated one of the principles related to processing (article 5.1.f) GDPR), so this argument cannot be accepted.

7. Size of Orange Bank S.A. Branch in Spain.

In this case, the circumstances of the case are taken into account for the imposition of the sanction: the severity of the infringement, the consequences of it, the lack of diligence shown, the specific processing it carries out, the type of personal data, and the number of affected individuals, all of which are highlighted and motivated in the Proposal for resolution of the present sanctioning procedure, to which we refer.

Also taken into account, in this case, are the allegations of ORANGE BANK regarding the size and business volume of the entity.

8. Lack of proportionality of the proposed sanction.

Regarding the non-compliance with the principle of proportionality, the GDPR expressly provides for the possibility of grading, through the provision of fines that can be modulated, taking into account a series of circumstances of each individual case.

The fact is that an infringement of article 5.1.f) of the GDPR has occurred, which must be sanctioned with a fine considering the serious concurrent individual circumstances. This fine must meet the characteristics imposed by article 83.1 of the GDPR, that is, it must be individualized and be effective, proportionate, and dissuasive.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
39/48

The administrative fine will be effective because it will lead the company to implement the technical and organizational measures that guarantee the confidentiality of the data subject to its processing. Likewise, the fine must be deterrent, in order to prevent the infringing behavior from being repeated in the future. In this sense, it should generate a deterrent effect regarding non-compliance and violation of data protection regulations and should never be more beneficial for the infringer than complying with

the breached norm.

Regarding the principle of proportionality of sanctions, the National Court has indicated in numerous rulings that the principle of proportionality cannot be exempt from judicial review, as the margin of appreciation granted to the Administration in imposing sanctions within the legally established limits must be developed by weighing, in any case, the concurrent circumstances, in order to achieve the necessary and due proportion between the alleged facts and the responsibility required, given that any sanction must be determined in accordance with the severity of the infringement committed and according to a criterion of proportionality in relation to the circumstances of the act. Thus, proportionality constitutes a normative principle that is imposed on the Administration and that reduces the scope of its sanctioning powers.

Well, taking into account the amount to which such sanctions may ascend in accordance with Article 83.5 of the GDPR, which provides for a fine of up to €20,000,000 or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount, and that ORANGE BANK has demonstrated that its turnover in the year 2022 amounted to (...) €, this is the amount that must be considered when setting the maximum limit of the fine.

Furthermore, the circumstances of the specific case are taken into account: the severity of the infringement, the consequences thereof, the lack of diligence shown, the specific treatments carried out, the type of personal data, and the number of affected individuals, the circumstances of the company (size, turnover, etc.), all of which are evidenced and motivated in the Initiation Agreement of this sanctioning procedure and are reproduced in this Resolution, to which we refer, which allows us to anticipate that the principle of proportionality has been respected when determining the amount of the fine ultimately imposed.

9. Qualification of the infringement as very serious.

As has been evidenced in the instruction of this procedure, the imposition of the sanction derives from proven facts that constitute a very serious infringement of the GDPR.

The facts are attributed to Orange Bank S.A. Branch in Spain, as the data controller, for the violation of the principle of Article 5.1.f) of the GDPR.

The Agency considers that the nature of the infringement is very serious since it entails a significant risk to the rights of the affected individuals due to the irreversible loss of disposition and control of personal data, which must...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
40/48

the assertion that “Orange Bank S.A. Branch in Spain cannot be held completely lacking in foresight and responsibility in the protection of data and, therefore, cannot be attributed the infringement of the principles of Article 5 of the GDPR” is categorically rejected.

It is pertinent to bring to mind Judgment 292/2000, of November 30, from the Constitutional Court, which establishes the right to data protection as an autonomous and independent right that consists of a power of disposition and control over personal data, enabling the individual to decide which of those data to provide to a third party, whether the State or a private individual, or what data this third party may collect, and also allowing the individual to know who possesses that personal data and for what purpose, being able to oppose such possession or use.

Thus, according to Legal Ground 6 of the Judgment of the High Court:

“6. The function of the fundamental right to privacy under Article 18.1 of the Spanish Constitution is to protect against any invasion that may occur in that area of personal and family life that the individual wishes to exclude from the knowledge of others and from the intrusions of third parties against their will (see, among others, STC 144/1999, of July 22, FJ 8). In contrast, the fundamental right to data protection seeks to guarantee that individual a power of control over their personal data, over its use and destination, with the aim of preventing its illicit trafficking and harm to the dignity and rights of the affected party. Ultimately, the right to privacy allows for the exclusion of certain data about a person

from the knowledge of others; for this reason, and as this Court has stated (SSTC 134/1999, of July 15, FJ 5; 144/1999, FJ 8; 98/2000, of April 10, FJ 5; 115/2000, of May 10, FJ 4), it is to safeguard their private life from unwanted publicity. The right to data protection guarantees individuals a power of disposition over that data. This guarantee imposes on public authorities the prohibition of becoming sources of that information without the necessary safeguards; and also the duty to prevent the risks that may arise from unauthorized access or disclosure of that information. However, that power of disposition over one's own personal data is of no value if the affected party is unaware of what data is held by third parties, who holds it, and for what purpose."

Therefore, any action that deprives a person of those powers of disposition and control over their personal data constitutes an attack and a violation of their fundamental right to data protection.

(...)

Having this measure in place beforehand would have very likely prevented access to such data, which means that the risk of loss of confidentiality has materialized, resulting in a total and absolute loss of control over it. This demonstrates a lack of diligence on the part of Orange Bank S.A. Branch in Spain in implementing appropriate technical measures to ensure an adequate level of security relative to the risk to the rights and freedoms of individuals.

The fact that Orange Bank S.A. Branch in Spain is a company that, in its financial activities, constantly and abundantly handles personal data, performing processing that involves a probable high risk to the rights and freedoms of individuals.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

41/48

The freedoms of individuals require a greater diligence in the processing of personal data than what may be required regarding processing activities that do not involve the constant handling of data.

10. Necessity for the resolution proposal to be adapted to the factual circumstances that have been corrected or nuanced.

In this regard, it should be noted that the allegation made by Orange Bank concerning the actual turnover of the entity is taken into account.

However, this Agency must record that, in the grading of the sanction and given the specialty of the matter, the criteria are taken into account by imperative of Article 83.2 of the GDPR and of paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD.

V Integrity and confidentiality

Article 5.1.f) "Principles relating to processing" of the GDPR establishes:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures an appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality')."

In the same sense, Recital 39 of the GDPR states that: "Personal data must be processed in a manner that ensures an adequate security and confidentiality of personal data, including to prevent unauthorized access or use of such data and of the equipment used in the processing."

The principle of integrity and confidentiality of data requires a guarantee of security in the application of technical or organizational measures that prevent the alteration of personal data, its loss, unauthorized or unlawful processing or access. The existence of this fundamental right is not possible if confidentiality, integrity, and availability of these are not guaranteed.

Thus, the integrity and confidentiality of personal data are considered essential to prevent data subjects from suffering negative effects. Therefore, they must be processed in a manner that ensures adequate integrity and confidentiality of personal data, especially to prevent unauthorized access, processing, or use of such data.

Ultimately, it is the data controller who has the obligation to integrate the necessary guarantees in the processing, with the aim of, under the principle of proactive responsibility, complying with and being

able to demonstrate compliance, while respecting the fundamental right to data protection.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

42/48

In this regard, it should be remembered that the confidentiality of personal data is regulated in Article 5 of the GDPR and is, therefore, one of the principles relating to processing. The principles relating to processing are, on one hand, the starting point and the closing clause of the legal framework for data protection, constituting true guiding rules of the system with an intense expansive force; on the other hand, having a high level of concreteness, they are mandatory norms that can be infringed.

Therefore, the principle of confidentiality must inform all aspects, rights, and obligations involved in the processing of personal data. This is so because the violation of confidentiality leads to the loss of control over the data for its holders, which can pose serious risks to their rights and freedoms.

Article 5.1.f) of the GDPR establishes a clear obligation of compliance consisting of preventing unauthorized or unlawful processing by implementing appropriate security measures. Consequently, data controllers must be in a position to guarantee the confidentiality of personal data to prevent a third party from accessing data that does not belong to them, as it is precisely their responsibility to process personal data in accordance with the GDPR and LOPDGDD. For this reason, the diligence exercised by them is fundamental to avoid such unauthorized access.

In the present case, the principle of confidentiality has been violated as it is recorded that after suffering a ransomware cyberattack, there was an unauthorized access to personal data, which resulted in the loss of confidentiality and control over the data.

(...):

-

(...)

-

(...)

-

(...)

-

(...)

-

(...)

-

(...)

-

(...)

(...)

(...)

(...)

This loss of control over one's own personal data translates into a violation of the fundamental right to data protection recognized in Article 18 of the Spanish Constitution, as indicated by the Constitutional Court (Judgment 292/2000, of November 30, 2000) "the fundamental right to data protection seeks to guarantee the individual a power of control over their personal data, over its use and destination, with the purpose of preventing its unlawful trafficking and

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

43/48

harmful to the dignity and rights of the affected party (...) The right to data protection guarantees

individuals a power of disposal over that data.”

In this same sense, it must also be noted that there are measures specifically aimed at ensuring the confidentiality of personal data, such as the encryption of such data or the application of pseudonymization or anonymization techniques to them, measures that, if applied, would have at least made it difficult for an unauthorized third party to access the personal data and, consequently, the subsequent publication of the same. This is because the loss of confidentiality was confirmed as a consequence of the exfiltration of the data; loss of confidentiality, access by a third party to the personal data, which would not have occurred if these had been encrypted or pseudonymized or anonymized, as the criminals would have taken away unintelligible information.

Consequently, it is considered that the established facts constitute an infringement, attributable to the investigated entity, for violation of Article 5.1.f) of the GDPR.

VI Qualification of the infringement of Article 5.1.f) of the GDPR

The aforementioned infringement of Article 5.1.f) of the GDPR entails the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

“The infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% at most of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements.”

For the purposes of the statute of limitations, Article 72 “Infringements considered very serious” of the LOPDGDD indicates:

“1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the infringements that constitute a substantial violation of the articles mentioned therein are considered very serious and shall prescribe after three years, particularly the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)”

VII Sanction

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

44/48

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 is, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those contemplated in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage suffered;

b) the intentionality or negligence in the infringement;

c) any measures taken by the controller or processor to mitigate the damage suffered by the data subjects;

- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42,
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

For its part, Article 76 “Sanctions and corrective measures” of the LOPDGDD provides:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

45/48

- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) To have, when not mandatory, a data protection officer.
- h) The voluntary submission by the responsible party or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.

****Sanction for the infringement of Article 5.1.f) of the GDPR****

In accordance with the transcribed provisions, for the purpose of determining the amount of the sanction for the infringement of Article 5.1 f) of the GDPR, it is appropriate to adjust the fine taking into account:

****As aggravating factors:****

- Article 83.2.a) GDPR: Nature, severity, and duration of the infringement.

It is considered that the nature of the infringement is serious since it entails a loss of confidentiality and, therefore, of irretrievable disposition and control over personal data.

- Number of affected parties: (...)

(...)

- (...):

☐ (...)

☐ (...)

☐ (...)

☐ (...)

☐ (...)

□ (...)

□ (...)

- Article 83.2.b) GDPR. Intent or negligence in the infringement:

The Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. In assessing the degree of diligence, special consideration must be given to the professionalism or lack thereof of the subject, and there is no doubt that, in the case now examined, when the activity of the investigated entity involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard. [Judgment of the National Court of 17/10/2007 (rec. 63/2006)]. In this case, there was gross negligence.

It is also considered appropriate to adjust the sanction to be imposed in accordance with the following criteria established in section 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

****As aggravating factors:****

- Article 76.2.b) LOPDGDD. Connection of the infringer's activity with the processing of personal data:

It is well known that the investigated entity is one that processes a large volume of personal data of its own clients, which are systematically processed in the exercise of its banking activity that has been affected by the personal data breach.

Consequently, for the purpose of complying with the legally established requirements, the exercise of such activity necessarily implies knowledge and application of the current regulations on personal data protection.

This circumstance determines a greater degree of demand and professionalism and, consequently, of responsibility of the entity, in relation to the processing of personal data.

Considering the factors presented, given that Orange Bank has demonstrated that its turnover for the year 2022 amounted to (...) € and that fines must be effective, proportionate, and dissuasive in each individual case, the assessment of the amount of the fine is 200,000 euros.

****VIII Adoption of measures****

The text of the resolution establishes what the infringements committed have been and the facts that have led to the violation of data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, since it is the data controller who fully knows its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

Therefore, it is considered appropriate to order the responsible party to adopt the necessary measures to ensure the confidentiality of the data subject to its applicable processing and to communicate this to this Agency within six months from the finality of the resolution that concludes this procedure.

It is warned that failure to comply with the order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

47/48

Article 83.5 and 83.6, such conduct may lead to the initiation of further administrative sanctioning proceedings.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on ORANGE BANK, S.A. BRANCH IN SPAIN, with NIF W2503011E,

-for the infringement of Article 5.1.f) of the GDPR, classified in accordance with the provisions of Article 83.5 of the GDPR, qualified as very serious for the purposes of prescription, under Article 72.1 a) of the LOPDGDD, a fine of 200,000 euros.

SECOND: TO ORDER ORANGE BANK, S.A. BRANCH IN SPAIN, with NIF W2503011E, that pursuant to Article 58.2.d) of the GDPR, within 6 months from the date this resolution becomes final and enforceable, to demonstrate that it has implemented the necessary measures to ensure the confidentiality of the data subject to its processing, as well as to inform this Agency, within the same period, about the measures adopted.

THIRD: TO NOTIFY this resolution to ORANGE BANK, S.A. BRANCH IN SPAIN.

FOURTH: This resolution will be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right.

The sanctioned party is warned that it must comply with the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No.

IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed during the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

In accordance with the provisions of Article 76.4 of the LOPDGDD and given that the amount of the imposed sanction exceeds one million euros, the information identifying the offender, the infringement committed, and the amount of the sanction will be published in the Official State Gazette.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Presidency of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the final resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal.

If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation proving the effective filing of the contentious-administrative appeal. If the Agency does not receive knowledge of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension will be considered terminated.

938-101224

Olga Pérez Sanjuán

The Deputy Director General of Data Inspection, in accordance with Article 48.2 LOPDGDD, due to vacancy in the position of Presidency and Deputy Presidency

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es